Progettazione e realizzazione di un monitor di accessi a file basato su BPF-LSM nel kernel Linux

Tesi di Laurea in

Ingegneria Informatica

Candidato
Luca Maffioli

Relatori
Prof. Giuseppe Lettieri
Dott. Fabio Piras



UNIVERSITÀ DI PISA



Introduzione e Problema

Contesto

La sicurezza nei sistemi Linux si basa sulla prevenzione.

Un **monitor** la affianca segnalando anche gli accessi consentiti ai file sensibili, che possono nascere da errori di configurazione o da privilegi eccessivi.

Il monitor è realizzato con **eBPF**, che permette di eseguire nel kernel programmi verificati, invocati quando avvengono specifici eventi.

Problema

L'utente indica un file con il suo path, il kernel lavora sull'oggetto identificato dalla coppia device e inode. Una sostituzione o un hard link possono modificare il legame tra i due.

Il **criterio** con cui riconoscere ad ogni apertura i file da sorvegliare è il centro del lavoro.



Soluzioni

- **v1 · Inode**
  Il file è riconosciuto con l'**inode**; se viene sostituito il riferimento si perde.

- **v2 · Inode vs path**
  Confronto tra criterio per **path** e **inode**. Ognuno perde il file in casi diversi, quindi nessuno basta da solo.

- **v3 · Strategia ibrida**
  Il path indica il file da proteggere e l'inode l'oggetto corrispondente. Il legame è mantenuto osservando rinomine, cancellazioni e link.

- **v4 · Mount namespace**
  Con i container lo stesso path può indicare un altro file, che fuori dal **namespace** del monitor non viene scambiato per quello sorvegliato.



Risultati

Macchina host

Il file sorvegliato è individuato anche quando cambia oggetto o nome, come dopo un salvataggio con vim, una sostituzione con mv, un hard link o una rinomina, e un inode riusato non provoca falsi positivi.

Container

Il file dell'host è riconosciuto anche quando è montato nel container o aperto da un container privilegiato; sono anche segnalate le operazioni fatte dall'interno.

Per riconoscere un file in modo affidabile **non basta un solo criterio**, ma bisogna combinare path, inode e mount namespace e osservare le operazioni che cambiano il legame tra nome e oggetto.